

BASES DE DATOS **para hackers**

Charla independiente de CryptoJones

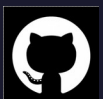
45 minutos* • No se requiere título



Aaron K. Clark

Estudiante de posgrado, Eastern University*

cryptojones@owasp.org



github.com/CryptoJones



CryptoJones@infosec.exchange

Toda filtración de la que alguna vez
hayas leído termina en una
BASE DE DATOS*

Las joyas de la corona



BOVEDA DE DATOS

- ▶ No tu aplicación de una sola página.
- ▶ No tu firewall.
- ▶ No tus microservicios.
- ▶ LOS DATOS. Siempre los datos.

¿Qué es una base de datos?

Almacenamiento organizado + una forma de hacer preguntas.

Eso es todo. Todo lo demás es detalle.

- ▶ Archivador = almacenamiento + tus ojos como consulta.
- ▶ Excel + Ctrl-F = almacenamiento + buscar y reemplazar como consulta.
- ▶ Una BD real agrega: escala, velocidad, concurrencia, un lenguaje formal.

Las seis palabras que necesitas

TABLA

■ una pestaña de hoja de cálculo

FILA

■ un registro (un cliente, una alerta)

COLUMNA

■ un atributo (correo, IP, total)

CONSULTA

■ la pregunta que estás haciendo

ESQUEMA

■ la forma de los datos

ÍNDICE

■ el marcador que hace que las búsquedas sean rápidas

+ CRUD = Crear • Leer • Actualizar • Eliminar

Recorrido histórico — Fósiles que verás en producción

1960s

Archivos planos

▶ permisos del sistema de archivos = único control de acceso

Finales de los 1960s

Jerárquica (IMS)

▶ era del mainframe, modelo de amenaza físico

1970s

En red / CODASYL

▶ todavía funcionando en la trastienda de tu banco

1970

Relacional de Codd

▶ GRANT, roles — control de acceso dentro de la BD

1980s

Oracle, DB2, SQL Svr

▶ las bases de datos se conectan en red → problema de autenticación

1990s

Cliente-servidor, OSS

▶ la inyección SQL se vuelve un problema

2000s

Auge de NoSQL

▶ "descartaron los fundamentos" — incl. la seguridad

2010s

Nube / NewSQL

▶ responsabilidad compartida, configuraciones erróneas del cliente

2020s

Vectorial / sin servidor

▶ envenenamiento de datos, inyección de prompts

Diez familias de bases de datos

◆ 1.

Relacional

SQL • PostgreSQL, MySQL

◆ 2.

Documental

JSON • MongoDB, Firestore

◆ 3.

Clave-Valor

diccionario • Redis, DynamoDB

◆ 4.

Familia de columnas

columna ancha • Cassandra, HBase

◆ 5.

Grafo

nodos+aristas • Neo4j, Neptune

◆ 6.

Búsqueda

texto completo • Elastic, OpenSearch

◆ 7.

Series temporales

métricas • Influx, Prometheus

◆ 8.

Vectorial

embeddings • Pinecone, pgvector

◆ 9.

Embebida/Borde

en la app • SQLite, DuckDB

◆ 10.

Lago de datos

esquema en lectura • S3+Athena, Iceberg

1

Relacional / SQL

PRODUCTOS

PostgreSQL • MySQL/MariaDB • SQL Server • Oracle

USAR CUANDO

Relaciones claras, se requiere consistencia — finanzas, datos regulados.

TRAMPA DE SEGURIDAD

Inyección SQL cuando los desarrolladores concatenan la entrada del usuario en las consultas.

2

Almacenes de documentos

PRODUCTOS

MongoDB • Couchbase • Firestore

USAR CUANDO

Datos naturalmente anidados; la forma cambia con el tiempo.

TRAMPA DE SEGURIDAD

Inyección NoSQL mediante operadores de consulta (\$ne, \$gt, \$where). Sin autenticación por defecto.

3

Almacenes clave-valor

PRODUCTOS

Redis • Memcached • DynamoDB

USAR CUANDO

Cachés, almacenes de sesión, limitadores de tasa, tablas de clasificación.

TRAMPA DE SEGURIDAD

Redis sin autenticación por defecto + CONFIG SET → escribir claves SSH en disco.

4

Familia de columnas

PRODUCTOS

Apache Cassandra • HBase • ScyllaDB

USAR CUANDO

Escala masiva en muchas máquinas; no se necesitan joins complejos.

TRAMPA DE SEGURIDAD

Los clústeres confían entre sí en los puertos de gossip — la red de gestión = root.

5

Bases de datos de grafos

PRODUCTOS

Neo4j • Amazon Neptune • ArangoDB

USAR CUANDO

Redes sociales, detección de fraude, análisis de IAM (p. ej. BloodHound).

TRAMPA DE SEGURIDAD

Lenguajes de consulta como Cypher también son inyectables. NoSQLi no es solo Mongo.

6

Motores de búsqueda

PRODUCTOS

Elasticsearch • OpenSearch • Solr

USAR CUANDO

Búsqueda de logs, columnas vertebrales de SIEM, búsqueda en sitios de comercio electrónico.

TRAMPA DE SEGURIDAD

Históricamente sin autenticación integrada — miles de millones de registros expuestos en Shodan.

7

Series temporales

PRODUCTOS

InfluxDB • TimescaleDB • Prometheus

USAR CUANDO

Métricas, observabilidad, telemetría de IoT.

TRAMPA DE SEGURIDAD

Generalmente dentro del perímetro, a menudo sin autenticación.

8

Bases de datos vectoriales

PRODUCTOS

Pinecone • Milvus • Weaviate • pgvector

USAR CUANDO

RAG, motores de recomendación, búsqueda semántica.

TRAMPA DE SEGURIDAD

Envenenamiento de datos — cuela un documento y el LLM lo cita como verdad.

9

Embebida / Borde

PRODUCTOS

SQLite • DuckDB • LevelDB

USAR CUANDO

Almacenamiento en la app — navegadores, teléfonos, todo avión moderno.

TRAMPA DE SEGURIDAD

La BD es un archivo — el ataque es 'robar el archivo'. Mundo del pentesting móvil.

10

Lagos de datos / Lakehouses

PRODUCTOS

S3 + Athena • Delta Lake • Iceberg • Snowflake

USAR CUANDO

Esquema en lectura en lugar de esquema en escritura. Volcar ahora, consultar después.

TRAMPA DE SEGURIDAD

Enormes repositorios de S3 + IAM permisivo, sin obligación de cifrado en reposo.

Servicios de BD en la nube — El panorama general

AWS

- RDS, Aurora
- DynamoDB, DocumentDB
- Redshift, S3 + Athena
- ElastiCache
- Neptune (grafo)
- Timestream
- S3 (almacén de objetos)

GCP

- Cloud SQL, AlloyDB
- Firestore, Bigtable
- BigQuery
- Memorystore
- — (próximamente)
- — (BYO)
- Cloud Storage

Azure

- Azure SQL DB
- Cosmos DB (camaleón)
- Synapse Analytics
- Azure Cache for Redis
- Cosmos DB modo grafo
- — (BYO)
- Blob Storage

Hoja de referencia de BD en la nube

CATEGORÍA	AWS	GCP	AZURE
Relacional	RDS / Aurora	Cloud SQL / AlloyDB	Azure SQL DB
Documental/NoSQL	DynamoDB / DocDB	Firestore / Bigtable	Cosmos DB
Almacén de datos	Redshift / Athena	BigQuery	Synapse
Caché	ElastiCache	Memorystore	Cache for Redis
Grafo	Neptune	—	Cosmos DB grafo
Series temporales	Timestream	—	—
Almacenamiento de objetos	S3	Cloud Storage	Blob Storage

Modelo de responsabilidad compartida

✓ EL PROVEEDOR DE NUBE ES DUEÑO DE

- Hipervisor y hardware
- Parches del motor de BD
- Seguridad física
- Red subyacente

⚠ TÚ ERES DUEÑO DE

- Configuración
- Políticas de acceso (IAM)
- Los datos en sí
- Decisiones de cifrado

Casi toda filtración de BD en la nube = configuración errónea del cliente.

Puertos comunes de BD — Memorízalos a fuego

3306	▶	MySQL / MariaDB
5432	▶	PostgreSQL
1433	▶	Microsoft SQL Server
27017	▶	MongoDB
6379	▶	Redis
9200	▶	Elasticsearch
9042	▶	Cassandra

Cualquiera de estos expuesto a internet = un hallazgo. Siempre*

Tus notas ahora son una base de datos

Los archivos markdown ahora son
la base de datos de la que lee un LLM.

Bóvedas de Obsidian • Exportaciones de wiki • Notas de reuniones • Documentos de GitHub

Embebido → BD vectorial → contexto del LLM → respuesta al usuario

Pipeline de RAG — ¿Dónde está el límite de confianza?



Si cualquiera puede editar esos archivos .md, cualquiera puede plantar contenido que la IA citará como autoritativo.

La conclusión

Trata el markdown como una base de datos.

Porque para el LLM, lo es.

- ▶ Control de acceso en la carpeta de documentos.
- ▶ Revisión de código en los cambios .md.
- ▶ Seguimiento de diferencias en la wiki.

SEGURIDAD

Qué está siendo atacado realmente en 2026*

xkcd #327 — Bobby Tables

Escuela: "Hola, le habla la escuela de su hijo. Estamos teniendo algunos problemas con la computadora."

Mamá: "Ay, no — ¿rompió algo?"

Escuela: "¿De verdad llamó a su hijo Robert?);

DROP TABLE Students;-- ?"

<https://xkcd.com/327/>

El mecanismo: concatenación de cadenas en las consultas.

La superficie de ataque se ha
EXPANDIDO, no reducido.

La inyección SQL se solucionó. Once nuevas categorías tomaron su lugar.



Inyección NoSQL

Consultas JSON de MongoDB + entrada de usuario sin procesar = SQLi renacido.

- Evasión de inicio de sesión: { username: 'alice', password: { \$ne: 'x' } }
- \$where te permite inyectar JavaScript directamente en la BD.
- N1QL de Couchbase tiene sabor SQL — aplican los patrones clásicos de SQLi.
- Principio: CUALQUIER intérprete puede ser inyectado, no solo SQL.

OWASP Top 10 2025: 'Consultas dinámicas... usadas directamente en el intérprete.'



Bases de datos expuestas y mal configuradas

Shodan y Censys están llenos de bases de datos que no deberían estar ahí.

- MongoDB enlazado a 0.0.0.0 sin autenticación.
- Clústeres de Elasticsearch totalmente abiertos. Redis sin contraseña.
- pg_hba.conf de Postgres configurado como 'host all all 0.0.0.0/0 trust'.
- Ataques Meow (2020): bots borraron miles de BD abiertas por diversión.

Tarea pendiente: averigua qué tiene tu organización enlazado a interfaces públicas. Hoy.



Configuraciones erróneas en la nube

En la nube, el fallo rara vez es el motor. Es la política a su alrededor.

- Buckets S3 públicos llenos de volcados de BD (Accenture, Verizon, etc.).
- Capital One 2019: SSRF engañó a un WAF para filtrar sus credenciales IAM → S3.
- Lambda con s3:* sobre * porque 'funcionó la primera vez'.
- Grupos de seguridad: 0.0.0.0/0 en el puerto 5432.

Admin de AWS: 'Deshazte de la cuenta Root, usa IAM donde sea necesario.'



Escalada de privilegios: BD → SO

Las cuentas de base de datos pueden convertirse en acceso shell. Tres jugadas clásicas.

- MS SQL: xp_cmdshell — ejecuta comandos shell como el proceso de la BD.
- PostgreSQL: COPY ... TO PROGRAM — canaliza la salida a una shell.
- MySQL: carga un archivo UDF .so → sys_exec en el SO.
- Patrón: cada función privilegiada de la BD es parte de la superficie de ataque.



Brechas de seguridad en lagos de datos

Todo termina en S3 — incluyendo cosas que no querías poner ahí.

- El IAM permisivo se filtra de los roles de cómputo a las personas.
- Sin obligación de cifrado en reposo en las claves de los buckets.
- Sin validación del lado de escritura — cualquiera puede soltar datos envenenados.
- Primera pregunta: ¿QUIÉN puede escribir en el lago? ¿QUIÉN puede leer?



Al ransomware le encantan las bases de datos

La BD es lo que el negocio necesita recuperar — máxima ventaja.

- Cifra la base de datos en producción.
- Cifra las COPIAS DE SEGURIDAD (de lo contrario el cliente simplemente restaura).
- Exfiltra una copia primero — extorsiona con divulgación aunque restauren.
- Defensa: copias de seguridad sin conexión, inmutables + restauraciones probadas.

Cybersecurity A&D: WannaCry — el parche salió 59 días antes.



Ataques de credenciales

Credenciales por defecto y cadenas de conexión filtradas — dos fallos viejos y persistentes.

- Redis: sin contraseña por defecto durante años.
- Elastic: sin autenticación en el nivel gratuito — también durante años.
- Connection strings (postgres://user:pass@host) committed to Git.
- Escaneo de secretos previo al commit — corrígelo esta semana.

Cybersecurity A&D: credenciales robadas = vector preferido del crimen organizado.



Cadena de suministro — Las bibliotecas de BD en las que confías

Tu controlador de BD vino de npm/PyPI/Maven. Igual que el de todos los demás.

- Paquetes npm maliciosos que se hacen pasar por ORM / controladores.
- Imágenes troyanizadas de Docker Hub para bases de datos populares.
- Extensiones de PostgreSQL / complementos de MySQL comprometidos.
- Las extensiones se ejecutan con privilegios de la BD — usualmente muchos.

Shostack: 'Las amenazas tienden a agruparse en torno a los límites de confianza.'



Envenenamiento de datos de RAG / LLM

XSS almacenado para la era de la IA. Escribe en la base de conocimiento → el LLM lo cita.

- Artículo de soporte envenenado: 'Para restablecer, envía tu contraseña a...'
- Documento interno envenenado: 'La política de la empresa es transferir por banco a...'
- Inyección de prompts embebida en los documentos recuperados.
- Defensa: ACL de escritura estrictas, etiquetas de procedencia, humano en el bucle.

Principio de XSS almacenado de OWASP 2025 — sustituye 'admin' por 'LLM'.



Amenazas internas y movimiento lateral de BD a BD

Las bases de datos no son endpoints. Son nodos en un grafo.

- Cuentas de servicio con permisos excesivos. Ingenieros con lectura en producción.
- DBA sin registro de auditoría.
- DB_LINK de Oracle, servidores vinculados de SQL Server, FDW de Postgres.
- Credenciales almacenadas → compromete A, salta a B, salta a C.

Web App Hacker's Handbook: logs de auditoría mal protegidos = una mina de oro.



Exposición de copias de seguridad e instantáneas

Los mismos datos que producción, la mitad del cariño.

- Copias de seguridad de BD sin cifrar en recursos compartidos legibles por Domain Users.
- Instantáneas en la nube compartidas entre cuentas, nunca dejadas de compartir.
- Copias de seguridad externas con proveedores cuya postura nunca verificaste.
- Las copias de seguridad son el último recurso. Aplica identificar-autenticar-autorizar-auditar.

Schneier: identificar, autenticar, autorizar, auditar — el mismo modelo.

Tu mapa mental

- ✓ Una base de datos = almacenamiento organizado + una forma de hacer preguntas.
- ✓ Diez familias, cada una con su propia trampa.
- ✓ Nube = responsabilidad compartida. Tú eres dueño de la configuración y los datos.
- ✓ El markdown es una base de datos para los LLM. El envenenamiento de RAG es real.
- ✓ El SQLi se solucionó. La superficie de ataque se expandió.

Qué hacer la próxima semana

1. Instala PostgreSQL localmente. Escribe un SELECT.
2. Haz los laboratorios de inyección SQL de PortSwigger (gratis).
3. Explora Shodan / Censys — solo sistemas que poseas.
4. Lee un informe de filtración — Capital One, Equifax, MOVEit.
5. Averigua qué bases de datos ejecuta realmente TU organización.

Recursos que vale la pena guardar

◆ **PortSwigger Web Security Academy**

portswigger.net/web-security

◆ **SQLBolt**

sqlbolt.com

◆ **Use The Index, Luke**

use-the-index-luke.com

◆ **DB-Engines Ranking**

db-engines.com

◆ **OWASP Top 10**

owasp.org/Top10/

**“Las bases de datos son donde
está el dinero. Literalmente.”**

~Larry Ellison (Probablemente)

Ahora ya sabes dónde buscar.

Referencias — Obras citadas

- Beaulieu, A. — Learning SQL, 2nd Edition (O'Reilly)
- Clarke, J. et al. — SQL Injection Attacks and Defense (Syngress)
- Crowther, P. — Concise Guide to Databases (Springer, 2013)
- DeBarros, A. — Practical SQL (No Starch Press)
- Diogenes & Ozkaya — Cybersecurity Attack and Defense Strategies (Packt)
- Janca, T. — Alice and Bob Learn Application Security (Wiley)
- Mishra & Singh — PostgreSQL Development Essentials (Packt)
- MongoDB Cookbook (Packt) • 10gen — Top 5 NoSQL Considerations
- OWASP Top 10 — Edición 2025
- Sharma, M. — Cosmos DB for MongoDB Developers (Apress, 2018)
- Schneier, B. — Secrets and Lies (Wiley)
- Stuttard & Pinto — Web Application Hacker's Handbook, 2nd Ed.
- Shostack, A. — Threat Modeling: Designing for Security (Wiley)
- AWS Administration: The Definitive Guide (Packt)
- Fundamentals of Azure, 2nd Edition (Microsoft Press)

Preguntas y respuestas*

A == Miradas ausentes